

Microsoft Entra ID

Custom Roles, Administrative-Unit Scoping (ABAC-Style Delegation) & Privileged Identity Management (PIM) Lab

Prepared by: Muhammad Danial

Role: IAM Engineer (Trainee)

Environment: Microsoft Entra ID Admin Center — Tenant "Epata"

1. Objective

This lab demonstrates the design and enforcement of least-privilege, attribute-scoped access in Microsoft Entra ID using three complementary controls: custom directory roles (fine-grained permission sets rather than broad built-in roles), Administrative Unit (AU) scoping (restricting a role's effective reach to a defined subset of objects, the closest native equivalent to attribute-based access control in Entra ID directory roles), and Privileged Identity Management — PIM (time-bound, justification-driven activation of privileged access instead of standing/permanent assignment). Together these controls illustrate how an IAM engineer can move an organization away from permanent, tenant-wide privileged roles toward just-enough-access, just-in-time delegation with a full audit trail.

Specifically, this lab covers:

- Reviewing the built-in role catalog and PIM's just-in-time access entry point in Roles and administrators.
- Assigning a built-in directory role (Application Administrator) directly to a user and verifying the resulting directory-scoped assignment.
- Reviewing an existing permanent PIM active assignment (Global Administrator) via My roles.
- Converting a role assignment from permanent to time-bound by setting an explicit assignment end date and a mandatory business justification (PIM active assignment).
- Designing and creating a custom directory role scoped to a single granular permission, rather than reusing an over-privileged built-in role.
- Creating an Administrative Unit and delegating the Groups Administrator role to a single user, scoped only to that Administrative Unit — restricting the blast radius of the delegated role.
- Validating every change end-to-end using the Roles and administrators audit log.

2. Lab Environment

Tenant	Epata (epata.onmicrosoft.com)
Administrator account	MuhammadDanial@Epata.onmicrosoft.com
Test identities used	Jaba, Khana, Nil (tenant users), plus the administrator's own account
Core features exercised	Roles & administrators, Custom roles, Administrative Units, Privileged Identity Management (PIM), Audit logs

3. Procedure

3.1 Baseline Review – Roles and Administrators

The lab began at Entra ID > Roles & admins > All roles, which lists every built-in directory role (e.g., Agent ID Administrator, Agent ID Developer, Agent Registry Administrator) along with its description, whether it is flagged

Privileged, and its current assignment count. The portal's own banner — "Get just-in-time access to a role when you need it using PIM" — was noted as the entry point that the rest of this lab builds on.

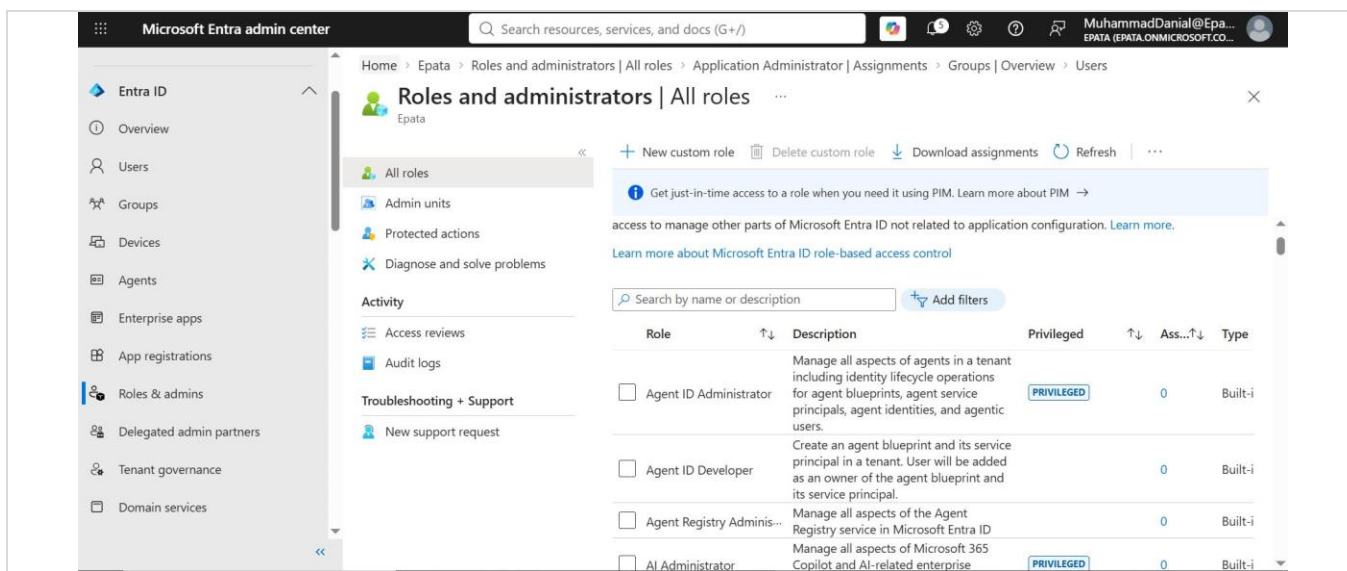


Figure 1 – All roles catalog for tenant Epata, with the built-in PIM just-in-time access banner.

3.2 Direct (Permanent) Role Assignment – Application Administrator

To establish a baseline before introducing PIM and scoping, the Application Administrator role was opened directly from Roles & admins. Its Assignments blade initially showed No role assignments found. From Add assignments, the user Khana was selected from the six available identities (Jaba, Khana, Muhammad Danial, Nil, and others) and assigned to the role.

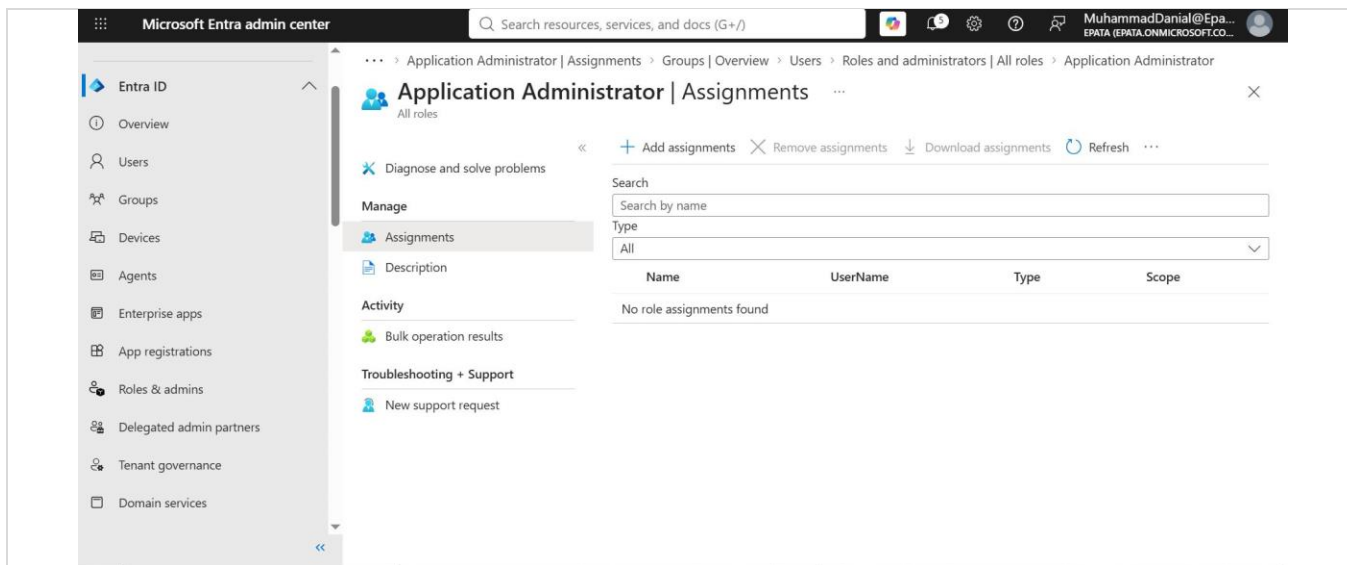


Figure 2 – Application Administrator role with no existing assignments.

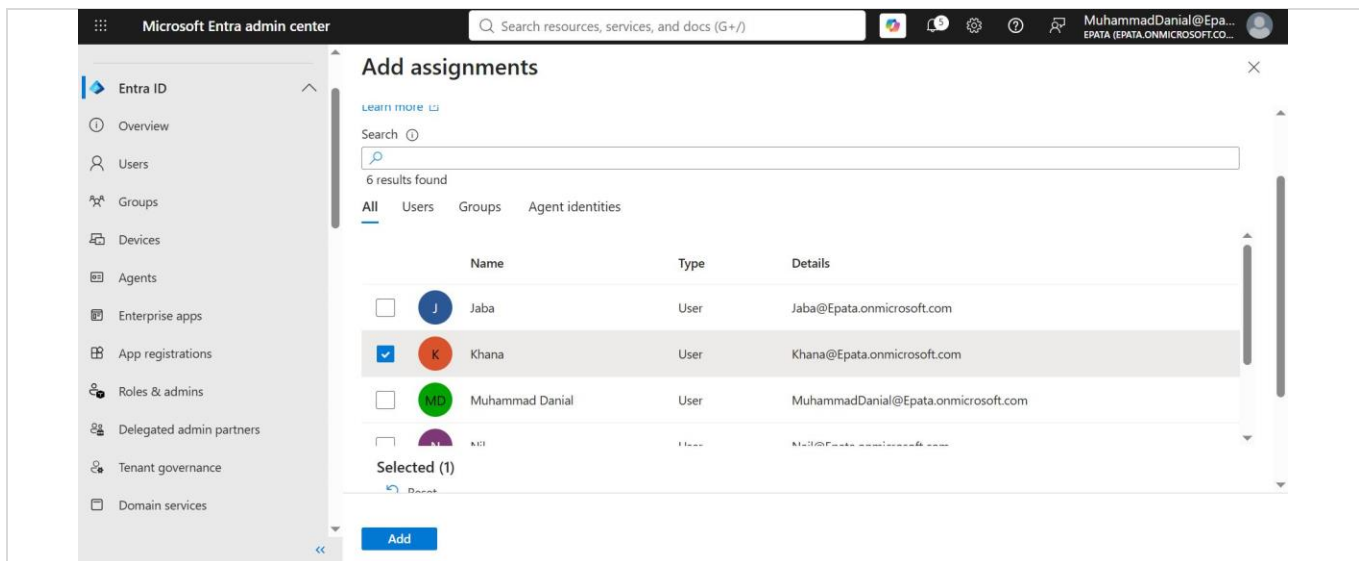


Figure 3 – Add assignments panel: user Khana selected for the Application Administrator role.

The Assignments blade was refreshed to confirm the result: Khana now appears as a User-type assignment with Directory scope — i.e., a standing (non-time-bound) permanent assignment applied tenant-wide, which is precisely the kind of over-broad, always-on privilege that PIM and scoping (sections 3.3–3.6) are designed to reduce.

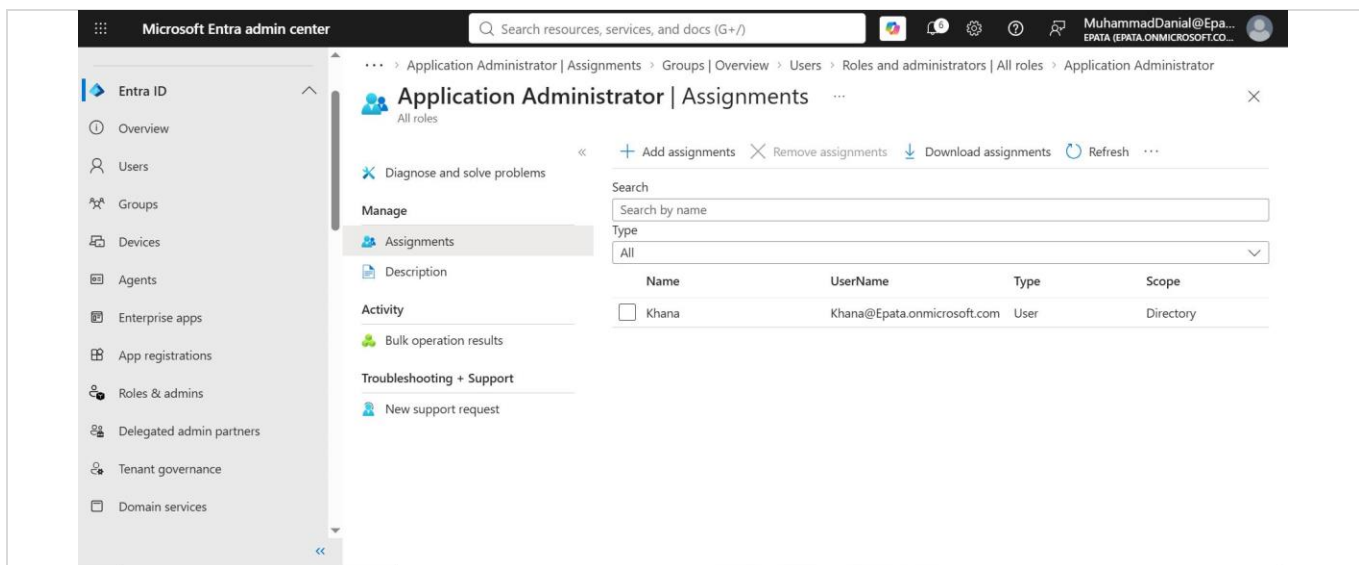


Figure 4 – Khana confirmed as a permanent Application Administrator assignment, Directory scope.

3.3 Reviewing an Existing PIM Active Assignment

Switching to Privileged Identity Management > My roles > Microsoft Entra roles > Active assignments surfaced the administrator's own Global Administrator role: Scope Epata, Membership Direct, State Assigned, End time Permanent. This confirmed that even the tenant's Global Administrator role was, at this point in the lab, provisioned as a standing assignment rather than a time-bound, activation-based one — the exact condition PIM is meant to eliminate for day-to-day operations.

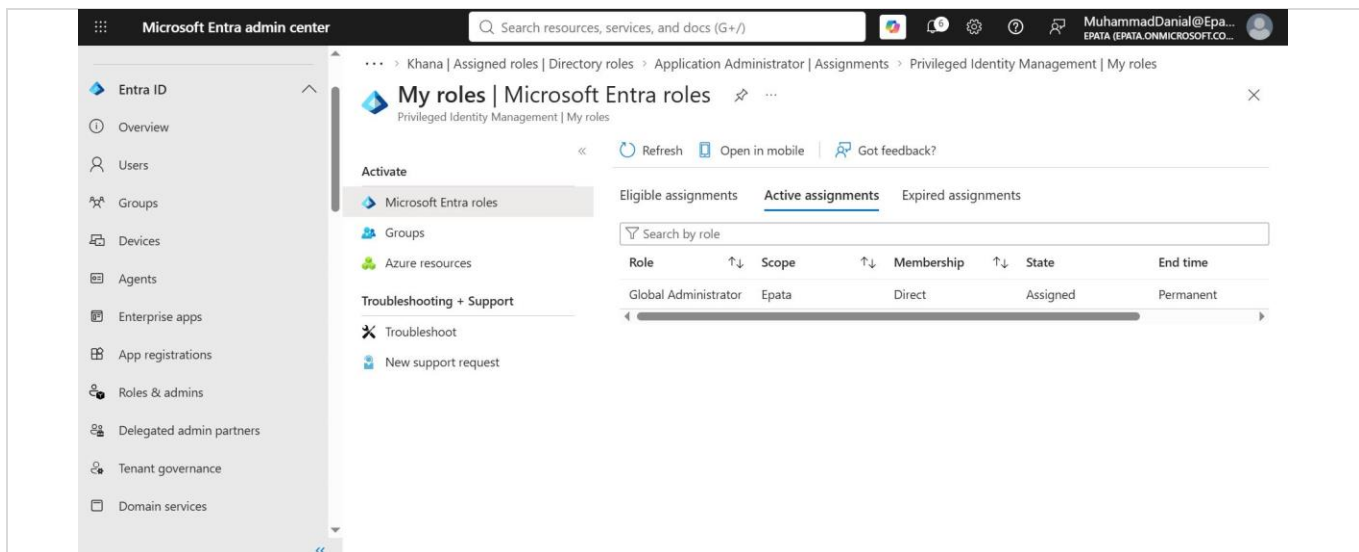


Figure 5 – PIM "My roles": Global Administrator shown as a permanent, direct, tenant-scoped active assignment.

3.4 Converting to a Time-Bound, Justification-Driven Assignment

To demonstrate PIM's attribute-driven access model, the user Jaba's Assigned roles > Active assignments entry was opened and edited via Membership settings. Rather than leaving the assignment Permanently assigned, an explicit Assignment ends date/time of 1/13/2027, 7:00:00 PM was set, and a mandatory justification — "The project deadline will be finished" — was recorded before saving. This models a real governance control: privileged access is granted only for the duration a business reason exists, and that reason is captured for audit at assignment time rather than reconstructed after the fact.

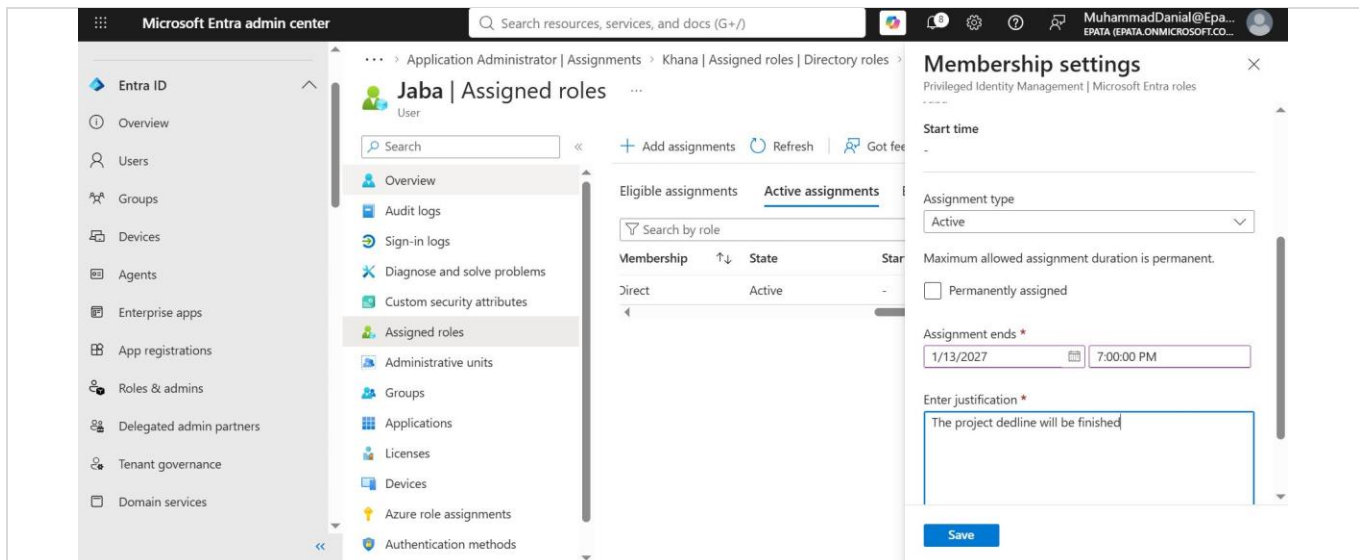


Figure 6 – PIM Membership settings for Jaba: assignment end date 1/13/2027 and a recorded justification, replacing a permanent assignment.

3.5 Creating a Least-Privilege Custom Role

Built-in roles are frequently broader than a given task requires. To scope access down to a single capability, a custom role was created from Roles & admins > New custom role:

1. Basics: Name = Test_1, Description = "Lab to test out features", Baseline permissions = Start from scratch (rather than cloning an existing role, to keep the permission set minimal).

2. Permissions: a single granular permission, `microsoft.directory/agentIdentities/appRoleAssignedTo/update` ("Update agent identity role assignments"), was selected — deliberately narrow in scope rather than a bundle of related permissions.
3. Review + create: the role definition was reviewed, confirming Name, Description, and the single permission, before creation.

The screenshot shows the 'New custom role' wizard in the Microsoft Entra admin center. The left sidebar contains navigation links: Entra ID, Overview, Users, Groups, Devices, Agents, Enterprise apps, App registrations, Roles & admins (selected), Delegated admin partners, Tenant governance, and Domain services. The main content area is titled 'New custom role' and shows the 'Basics' tab selected. Below the tabs, there is a text input for 'Name' and a text area for 'Description'. The 'Baseline permissions' section has two radio buttons: 'Start from scratch' (selected) and 'Clone from a custom role'. A 'Next' button is at the bottom right.

Figure 7 – New custom role wizard, Basics tab.

This screenshot shows the same 'New custom role' wizard, but with the 'Name' field filled with 'Test_1' and the 'Description' field filled with 'Lab to test out features'. The 'Start from scratch' radio button remains selected. The 'Next' button is still visible at the bottom right.

Figure 8 – Custom role named "Test_1" with description "Lab to test out features".

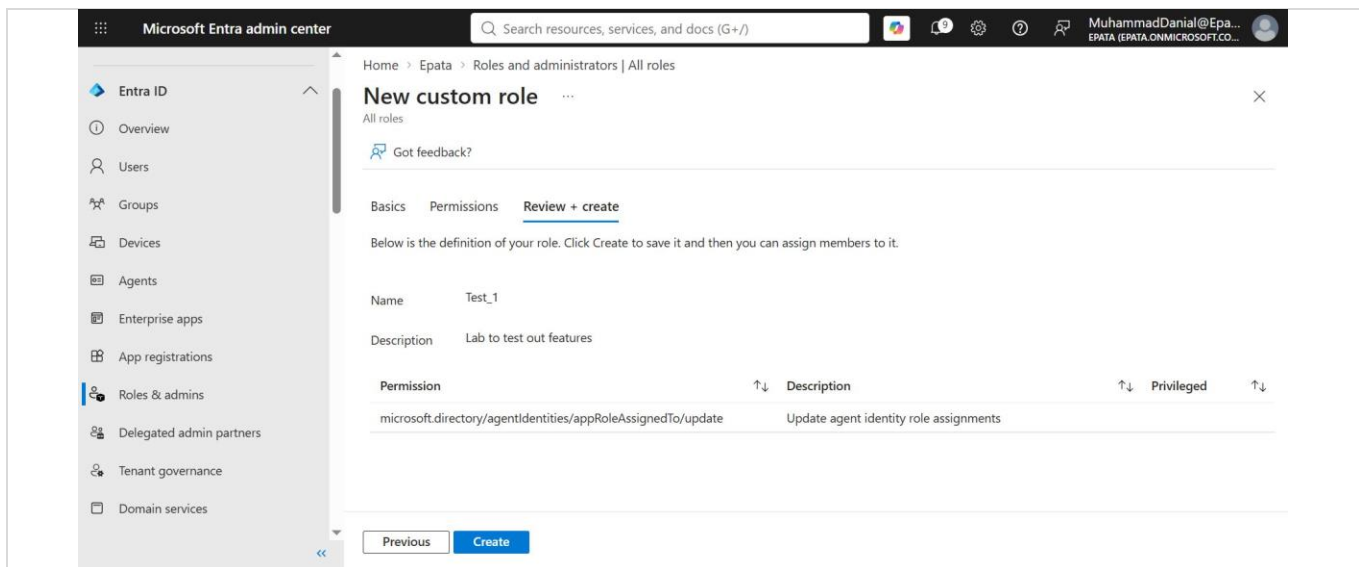


Figure 9 – Review + create: role scoped to exactly one permission, `microsoft.directory/agentIdentities/appRoleAssignedTo/update`.

After creation, `Test_1` was confirmed in the All roles list as a Custom-type role with 0 assignments, and its Description blade was reviewed to validate the recorded Template ID (52c7506d-1599-4fdc-a8b7-49438c512a2e) and the single role permission — providing a clean, auditable record of exactly what this role can and cannot do.

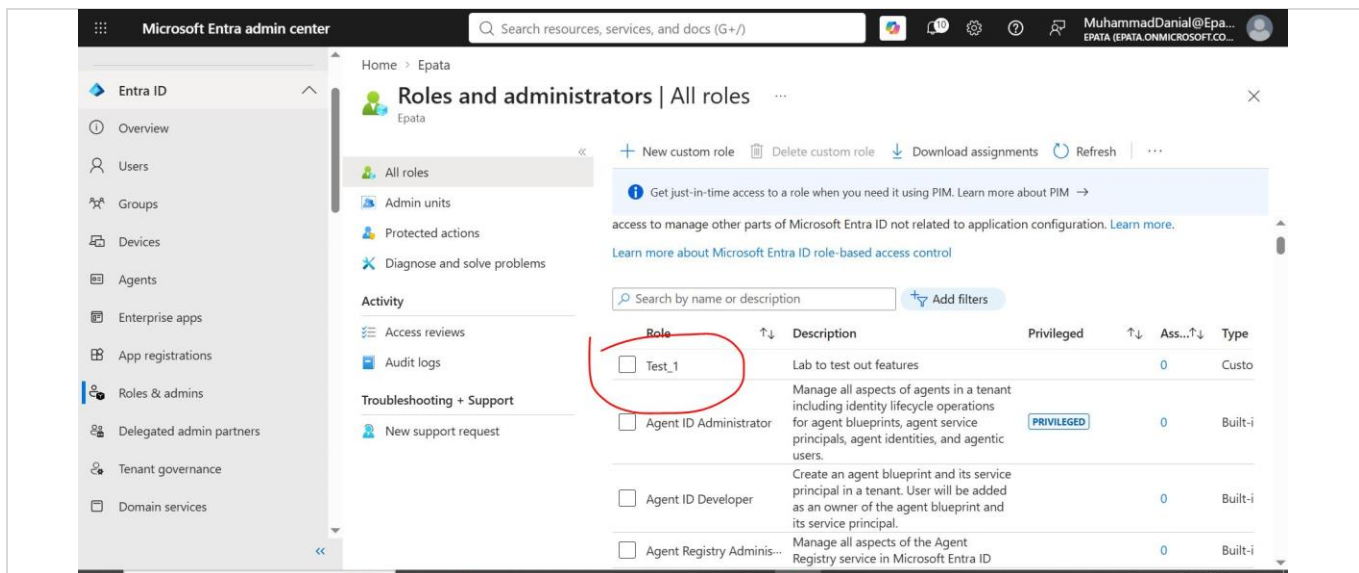


Figure 10 – `Test_1` confirmed in the All roles catalog as a custom role.

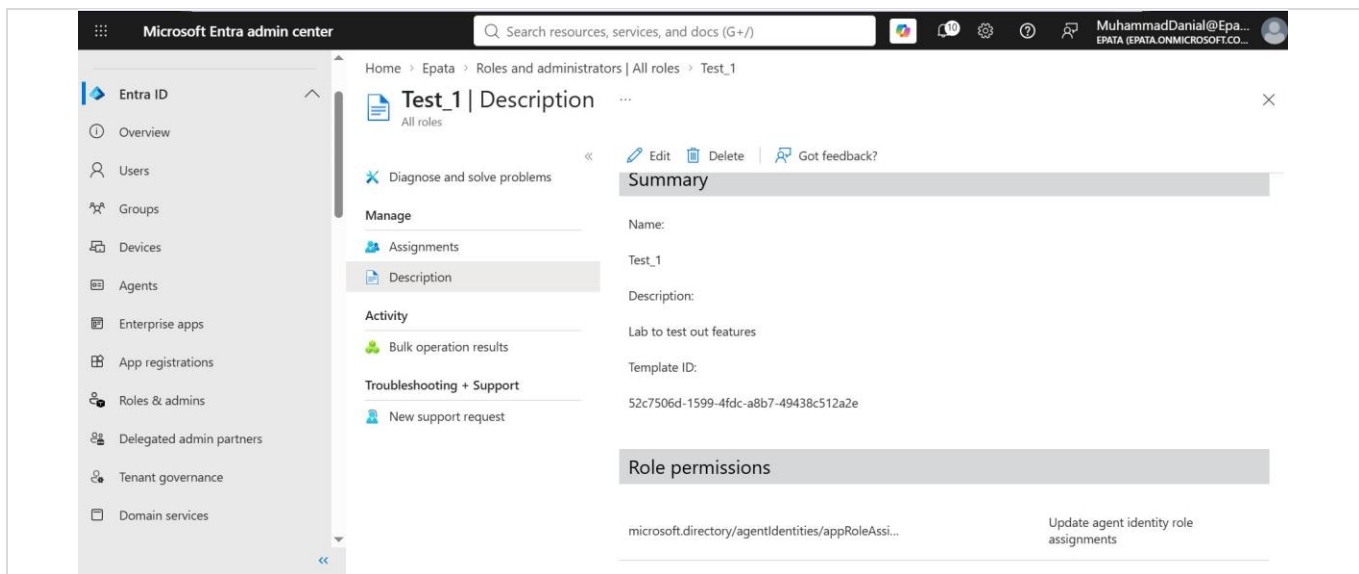


Figure 11 – Test_1 Description blade: Template ID and the single scoped permission.

3.6 Scoping Delegation with an Administrative Unit

To restrict a built-in role's effective reach — rather than its permission set — an Administrative Unit (AU) was used. Roles & admins > Admin units initially showed No administrative units found. A new AU was created via Add administrative unit:

4. Properties: the AU was named "It's a group test".
5. Assign roles: from the full list of eligible built-in roles (Attribute Assignment Reader, Authentication Administrator, Cloud Device Administrator, Entra SOC Identity Responder, Groups Administrator, Helpdesk Administrator, Hybrid Identity Administrator, License Administrator, Lifecycle Workflows Administrator, Password Administrator, Printer Administrator, etc.), Groups Administrator was selected as the role to delegate.
6. Assignments: the user Jaba was selected as the assignee for the Groups Administrator role, scoped to this AU only — rather than being granted Groups Administrator at the directory (tenant-wide) scope as was done for Khana in section 3.2.
7. Review + create: the summary confirmed Name = "It's a group test" and Assignment: Groups Administrator → Jaba, before the AU was created.

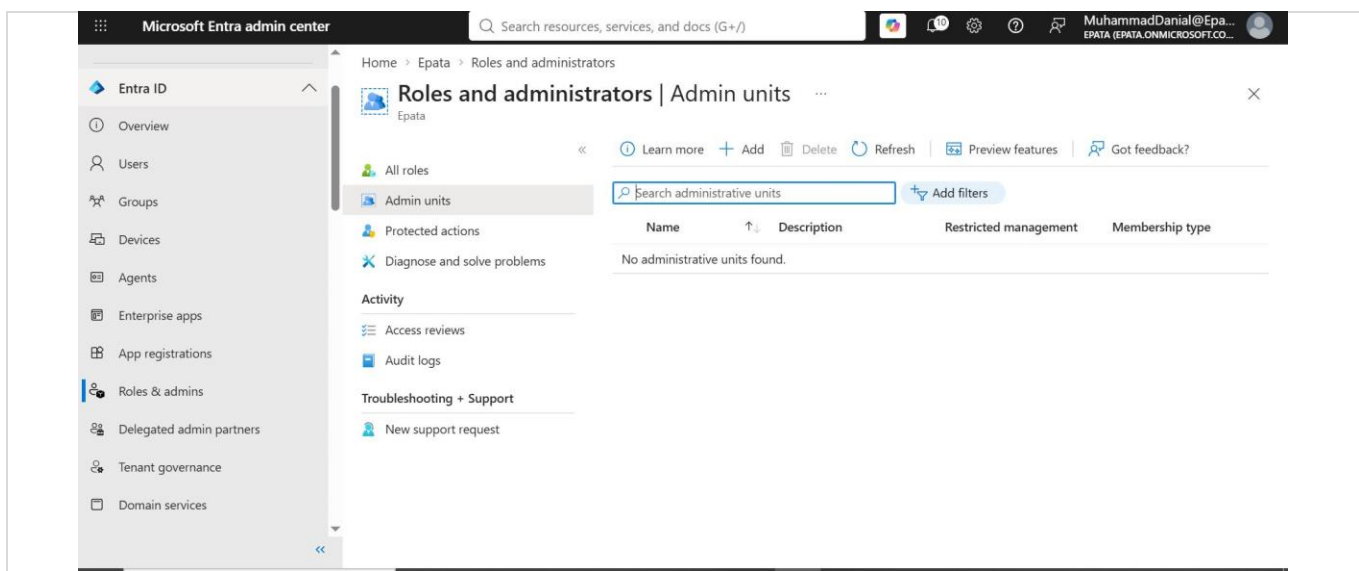


Figure 12 – Admin units blade, no administrative units yet configured.

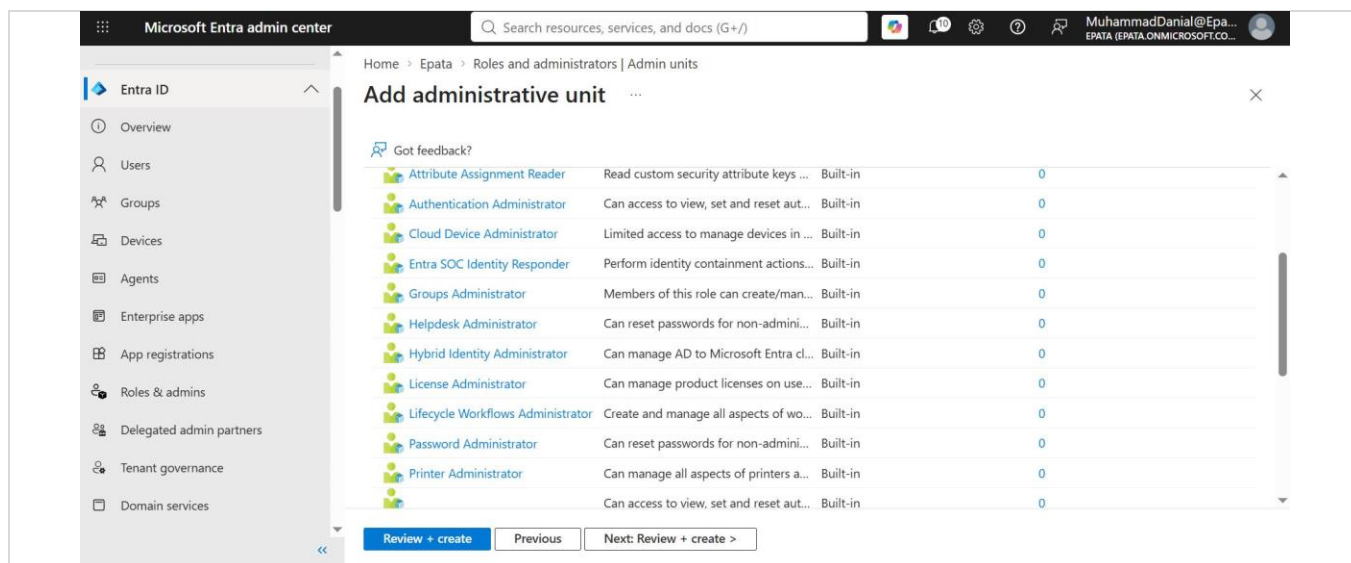


Figure 13 – Assign roles step: Groups Administrator selected from the built-in role catalog for AU-scoped delegation.

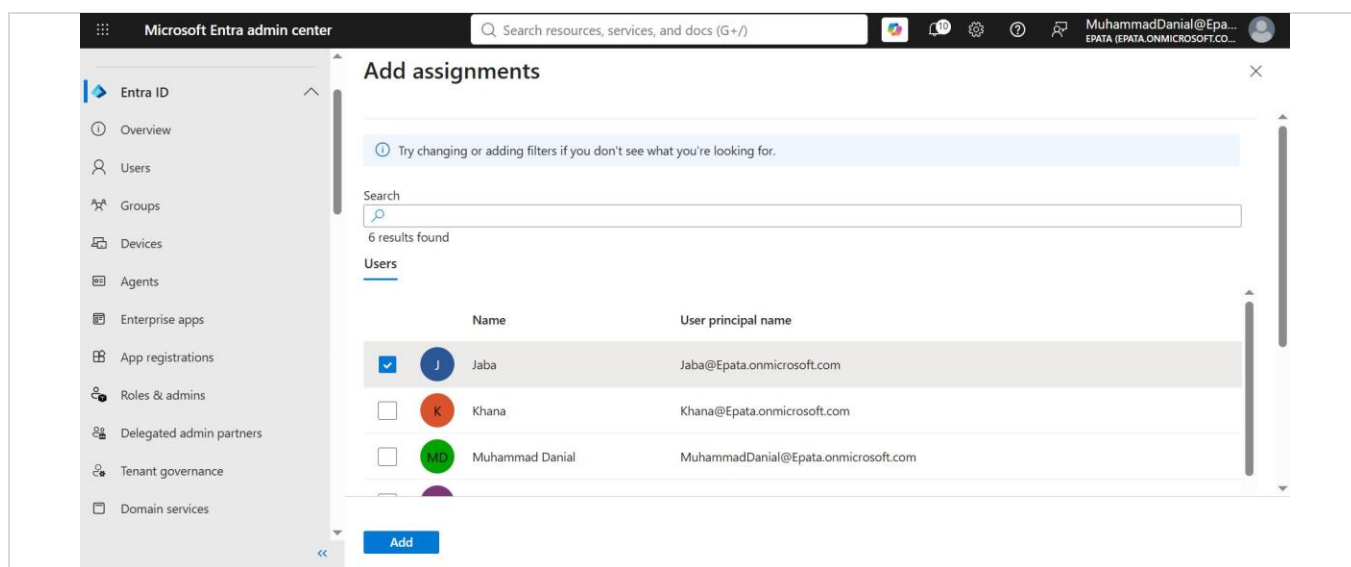


Figure 14 – Assignments step: Jaba selected as the Groups Administrator assignee, scoped to the new AU.

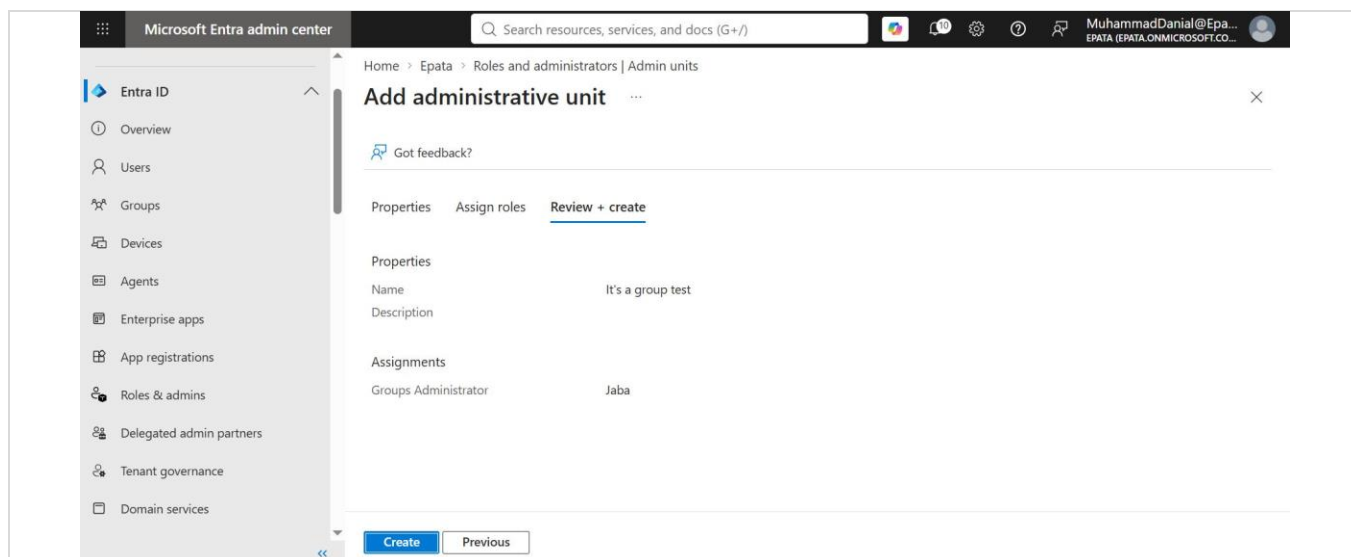


Figure 15 – Review + create: AU "It's a group test" with Groups Administrator delegated to Jaba.

The Admin units list was refreshed to confirm the AU "It's a group test" now exists (Restricted management: No, Membership type: Assigned). Opening the AU's own Roles and administrators blade confirmed Groups Administrator shows an assignment count of 1 — Jaba can now manage groups only within the boundary of this Administrative Unit, not across the entire Eptata directory, demonstrating attribute/scope-limited delegation as a native alternative to a tenant-wide role grant.

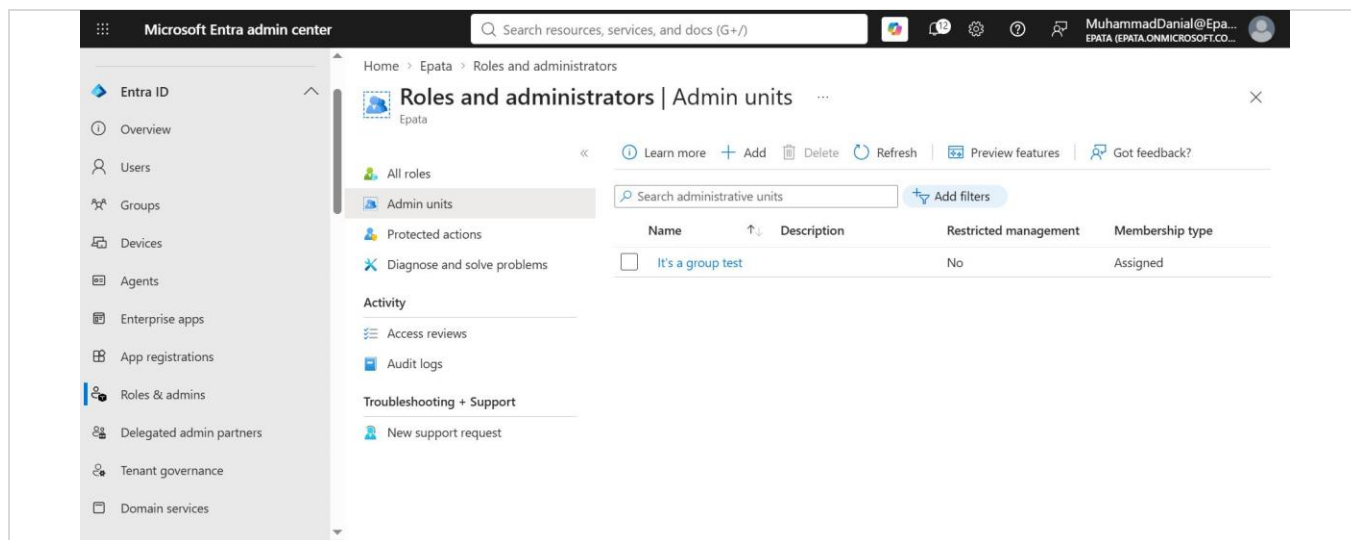


Figure 16 – Admin units list confirming "It's a group test" was created.

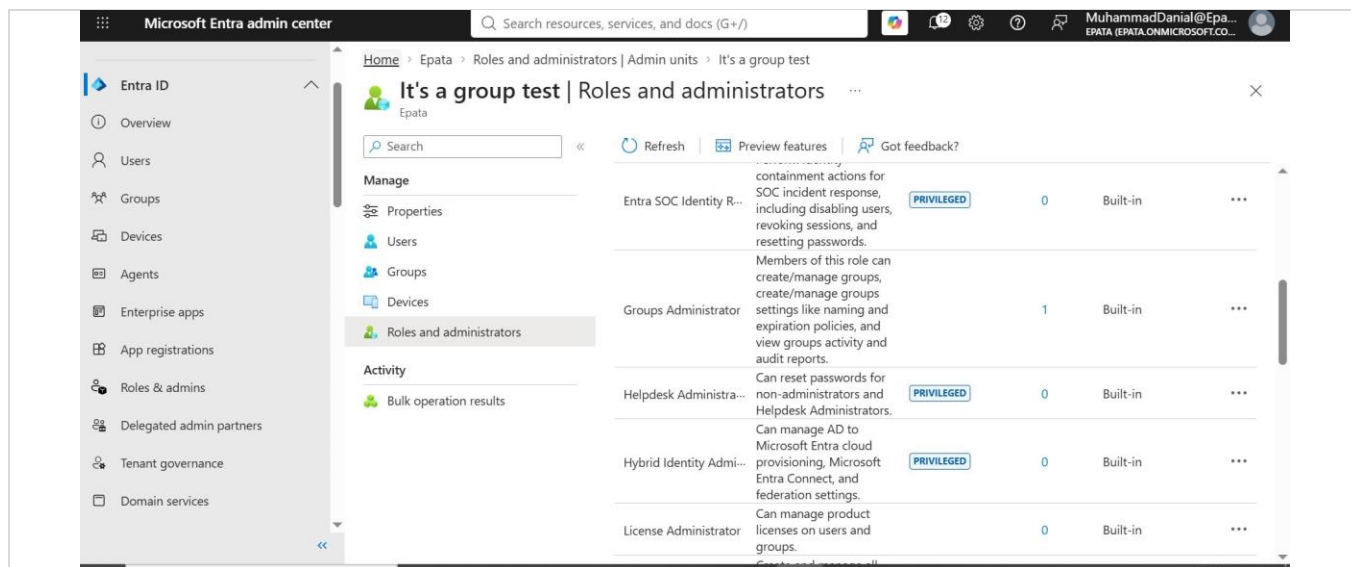


Figure 17 – AU-scoped Roles and administrators view: Groups Administrator shows 1 assignment (Jaba), bounded to this AU.

3.7 End-to-End Verification via Audit Logs

Finally, Roles & admins > Audit logs (Directory tab) was reviewed to validate every change made during this lab left a traceable record. The log confirmed, in sequence: Add scoped role and Add role definition entries (the custom role and AU-scoped role creation), multiple PIM / Core Directory Add member and Remove member entries under the RoleManagement category corresponding to the Jaba and Khana assignment changes, and a PIM Process role entry marking the completion of a PIM assignment operation — giving a complete, timestamped chain of evidence for every privileged-access change performed in this lab.

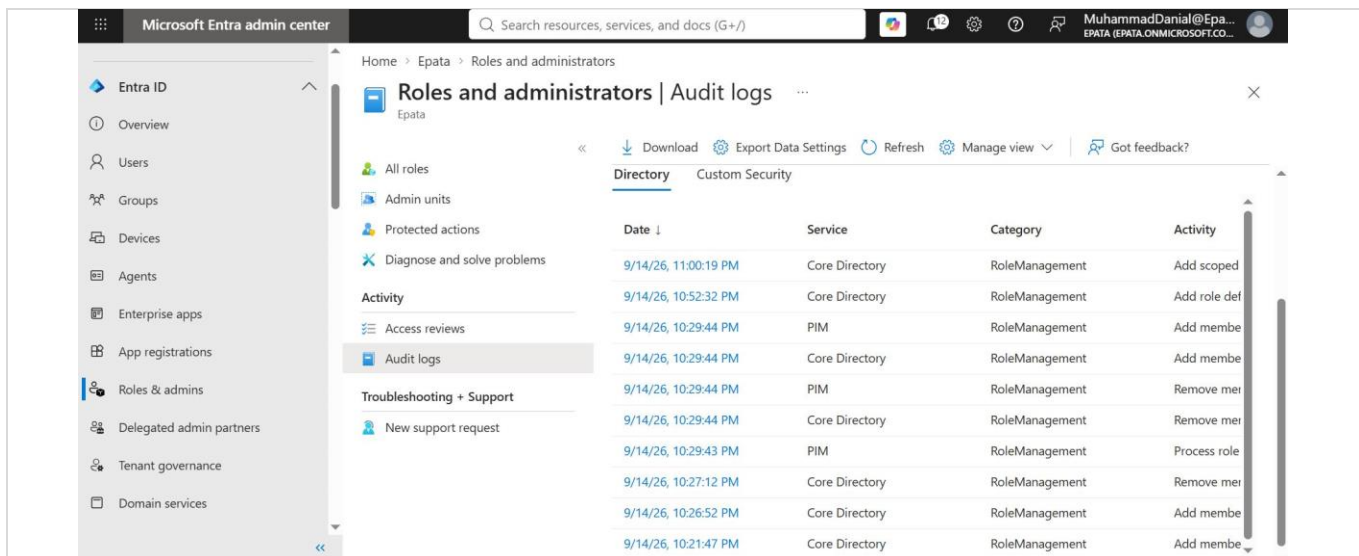


Figure 18 – Roles and administrators audit log: role definition creation, scoped role assignment, and PIM add/remove member activity, all timestamped.

4. Key Observations

- Entra ID directory roles do not support Azure-style attribute-based conditions (the true "ABAC" available on Azure resource RBAC); the native equivalents for attribute-like restriction are custom roles (restrict the permission set) and Administrative Units (restrict the object scope) — both were exercised in this lab to approximate least-privilege, condition-aware access.
- A role assignment made directly through Roles & admins (section 3.2) is permanent and directory-wide by default; the same privilege delegated through PIM or scoped to an Administrative Unit is materially safer, since it is either time-bound and justified, or bounded to a subset of objects, or both.
- PIM's Membership settings enforce a mandatory justification field on non-permanent assignments, providing an audit-ready business reason for privileged access at the moment it is granted rather than after the fact.
- Building a custom role from scratch with a single explicit permission (microsoft.directory/agentIdentities/appRoleAssignedTo/update) is preferable to assigning a broad built-in role when only one capability is actually required — this materially reduces the blast radius of a compromised or misused account.
- Administrative Units let the same built-in role (Groups Administrator) be delegated with two very different risk profiles: tenant-wide (as with Khana's Application Administrator assignment) versus scoped to a single AU (as with Jaba) — the AU-scoped grant is the safer delegation pattern for helpdesk- or team-level administrators.
- The Roles and administrators Audit logs blade is the definitive source of truth for proving what changed, when, and via which mechanism (Core Directory vs. PIM), and should be the first place an IAM engineer checks when validating or troubleshooting a privileged-access change.

5. Conclusion

This lab provided hands-on experience implementing least-privilege access in Microsoft Entra ID through three complementary mechanisms: custom directory roles scoped to a single permission, Administrative Unit-scoped role delegation, and Privileged Identity Management's time-bound, justification-driven active assignments. By directly contrasting a permanent, tenant-wide role assignment against its scoped and time-bound equivalents — and confirming every change in the audit log — the exercise reinforced practical, defensible reasoning about reducing standing privilege and the effective blast radius of every role grant. These are core competencies for an IAM engineer responsible for privileged access management (PAM) and access governance in an enterprise Microsoft Entra ID environment.

6. Skills Demonstrated

- Microsoft Entra ID role-based access control (RBAC) administration

- Custom directory role design and least-privilege permission scoping
- Administrative Units and scope-limited role delegation
- Privileged Identity Management (PIM): active assignments, time-bound duration, and mandatory justification
- Contrasting standing/permanent privileged access against just-in-time, scoped alternatives
- Audit log analysis for privileged-access change validation